

Reporte Ejecutivo de Riesgos

Clínica privada - evaluación inicial con SimpleRisk

Resumen ejecutivo

La evaluación inicial identificó siete riesgos relevantes para una clínica de 120 empleados que atiende aproximadamente 800 pacientes por día. La mayor exposición se concentra en el acceso a historias clínicas digitales, la continuidad de la atención y la resistencia frente a ataques de ransomware y phishing.

Los tres riesgos prioritarios obtuvieron 20 sobre 25 en la matriz académica y fueron clasificados como críticos. En SimpleRisk, esos riesgos se muestran en una escala normalizada de 0 a 10. Ya se definieron tres planes de acción, todos con estado inicial No iniciado (0 %).

7	5	3	USD 55.000
Riesgos evaluados	Riesgos prioritarios	Planes activos	Inversión propuesta

Top 5 riesgos por nivel

Prioridad	Riesgo	P	I	Nivel	Dimensión principal
1	Ransomware sobre historias clínicas	4	5	20 - Crítico	Disponibilidad
2	Acceso no autorizado con credenciales comprometidas	4	5	20 - Crítico	Confidencialidad
3	Phishing al personal médico y administrativo	5	4	20 - Crítico	Confidencialidad
4	Alteración de historias clínicas	3	5	15 - Alto	Integridad
5	Indisponibilidad por falla de infraestructura	3	5	15 - Alto	Disponibilidad

P: probabilidad; I: impacto. Escala académica de 1 a 5.

Estado de los planes de acción

Tres iniciativas inmediatas para reducir la exposición prioritaria

Plan	Responsable	Vencimiento	Presupuesto	Estado
Protección y recuperación frente a ransomware	Administrador de Seguridad	15/12/2026	USD 30.000	No iniciado
Fortalecimiento del control de acceso	Administrador de Seguridad	30/11/2026	USD 15.000	No iniciado
Prevención y detección de phishing	Analista de Riesgos	31/10/2026	USD 10.000	No iniciado

Recomendaciones prioritarias

- 1

Aprobar el programa contra ransomware. Implementar copias 3-2-1 aisladas e inmutables, protección EDR, segmentación de red y pruebas trimestrales de restauración.
- 2

Fortalecer identidad y acceso. Activar autenticación multifactor, eliminar cuentas compartidas y revisar trimestralmente privilegios y cuentas inactivas.
- 3

Reducir el riesgo humano. Realizar capacitación y simulaciones de phishing trimestrales, con un canal simple para reportar mensajes sospechosos.
- 4

Formalizar continuidad operativa. Definir procedimientos alternativos de atención, responsables, tiempos de recuperación y pruebas periódicas de contingencia.
- 5

Medir y reportar avances. Revisar mensualmente el porcentaje de mitigación, los incidentes detectados y el riesgo residual; informar al Directorio cada trimestre.

Decisión solicitada al Directorio
Aprobar una inversión inicial estimada de USD 55.000, designar responsables y solicitar un informe de avance mensual hasta completar los tres planes prioritarios.